

Platform Compliance Implementation Checklist

Engineering roadmap aligned to the customer legal-review package

WORKING IMPLEMENTATION DOCUMENT

Updated September 15, 2026

Status: implementation in progress

Last updated: September 15, 2026

Audit baseline: main at commit 35c20d4 plus the uncommitted security, payment-reliability, result/winner, and refund infrastructure working tree.

This checklist reflects the current working tree, including undeployed changes. It tracks engineering work needed to align Pin2Win with the repository legal package that the owner reported counsel accepted on September 15, 2026. Archived branches and unmerged prototypes are not counted as deployed. This is not a substitute for keeping counsel's written approval record or obtaining CPA advice.

Status key: [x] complete, [~] partially implemented, [] not implemented, [!] blocked by owner or professional input.

Important current-state note: New users must accept the legal documents and confirm age and Texas residency when creating an account. Existing accounts are grandfathered. Login, repeat QR scans, and checkout do not request consent again, and checkout does not currently require a stored acceptance record.

1. Legal Documents and Account Acceptance

- ☒ OK Publish permanent HTML routes for Terms of Use, Official Rules, Refund Policy, and Privacy Policy.
- ☒ OK Replace placeholder footer links with working internal links.
- ☒ OK Establish a single current legal-document version in application code.
- ☒ OK Display the owner-confirmed effective date and business mailing address in the legal package.
- ☒ OK Owner reported Texas counsel approval of the current repository legal package; versioned the online-claim operational amendment and removed the website draft banner. Retain the written approval record.
- ☒ OK Add unchecked account-creation acceptance controls with links to all four documents.
- ☒ OK Require separate age-18 and Texas-residency confirmations during account creation.
- ☐ Add or replace the onsite-presence control with a reliable transaction-specific location verification appropriate for direct QR checkout.
- ☒ OK Reject account creation server-side when required acceptance or eligibility confirmations are missing.
- ☒ OK Store an account-linked acceptance record with document version, acceptance text, UTC timestamp, IP address, and user agent.
- ☒ OK Preserve a SHA-256 hash of each accepted document and the combined legal package.
- ☐ ~ Existing accounts are intentionally grandfathered and do not have backfilled acceptance records.
- ☐ ~ Bind the exact accepted consent record, document version, and package hash to new Square checkouts and resulting entries when a record exists; grandfathered accounts and older/legacy checkouts remain explicitly unrecorded.

2. Challenge Configuration and Sale Controls

- ☐ Database models exist for challenges, locations, bays, simulator settings, entries, and prizes, but the customer checkout still uses hard-coded challenge configuration.
- ☐ Some challenge fields exist, but the enforceable configuration does not yet contain every material rule, shot setting, prize term, and sale control.
- ☐ Challenge, location, and bay relationships exist in the schema, but the public QR checkout does not enforce an authorized location-and-bay assignment.
- ☐ Reject checkout when a challenge is draft, paused, closed, completed, outside its sale period, or incompletely configured.
- ☐ Validate location and bay server-side instead of trusting QR query parameters.
- ☐ Display all material challenge details immediately before payment.
- ☐ Remove expired hard-coded May 2026 dates and fabricated fallback entry/result records; the test simulator event-code fallback and incomplete challenge configuration must still be removed after current production codes are saved.

3. Hole-in-One Result and Winner Controls

- ☐ ~ Replace the public and player closest-to-pin workflow with explicit hole-in-one reports; dormant legacy distance-scoring code remains and must not be re-enabled.
- ☒ OK Record a potential hole-in-one separately from a verified authenticated-simulator result; only verified reports appear in provisional public result views.
- ☐ ~ Require simulator source, session and shot IDs, shot time, venue, bay, one-stroke/holed flags, and evidence for verification; a real vendor or local-agent integration is not yet connected.
- ☒ OK Preserve append-only, attributed report, simulator-evidence, verification, rejection, and sale-resume events.
- ☐ ~ Require an individually authenticated MFA administrator and server-generated verification time; dedicated verifier roles are not yet implemented.
- ☐ ~ Select the provisional earliest verified shot by corroborated simulator time; equal or unreliable chronology remains unresolved rather than selecting a winner.
- ☒ OK Use a serializable database transaction and conflict retry for concurrent verification, entry status, sale closure, and provisional chronology.
- ☐ Implement the equal-split fallback when chronology cannot reliably be determined.
- ☐ ~ Pause application-issued new checkout/entry creation on a paid player's potential report or authenticated simulator report; Square links issued before the hold may still be payable.
- ☐ ~ Close new application checkout/entry creation after the first verified result; previously issued links may still be payable and need automatic identification of affected unused entries for refund review.
- ☐ Identify paid entries made unusable by challenge closure and provide an administrator-confirmed, idempotent Square refund action.

4. Winner Claim and Prize Administration

- ☒ OK Create a potential-winner claim record and MFA administrator workflow, separate from verified-shot chronology.
- ☐ ~ Track notice date, ten-day response deadline, eligibility review, acceptance or refusal, and disqualification; successor selection and equal split remain unresolved.
- ☐ Provide secure identity, Texas-residency, affidavit, and W-9 collection.
- ☐ ~ Potential-winner notices and admin notes explicitly prohibit tax identifiers and identity documents in ordinary email; a secure document-upload or verified external collection process remains to be selected.
- ☐ ~ Track finalization, 30-calendar-day payout target, payout approval, payment date, amount, and external method; finance reconciliation remains open.
- ☐ ~ Track tax-form preparation/delivery status only; the applicable form is a CPA decision, not assumed to be 1099-MISC.
- ☐ ! Have a CPA confirm W-9, whether 1099-MISC or W-2G applies, and any backup-withholding procedures.
- ☐ ! Confirm that the full advertised prize is reserved or insured before sales open.

5. Refund and Payment-Issue Handling

- ☒ OK Add a customer payment/refund claim page and authenticated API.
- ☐ ~ Capture claim reason, internal entry/payment identifiers, venue, date/time, narrative, evidence description, and bounded private PNG/JPEG/PDF attachments; antivirus/content disarm and retention controls remain open.
- ☒ OK Flag the accepted 14-calendar-day submission period from Square's verified payment date or later reported incident, never payment-link creation; unknown paid-at dates and legally required exceptions receive human review, never auto-denial.
- ☒ OK Add claim statuses, assignments, internal notes, customer-facing explanations, retryable customer/staff communications, and decision history.
- ☒ OK Add an authenticated, independently verified Square refund action with a durable idempotency key and provider refund ID.
- ☒ OK Add provider-pending, partial-refund, and refunded states to Square checkout and entry records; pause access for pending and fully refunded entries.
- ☒ OK Reserve a refund intent before the external provider call and update checkout/entry/claim atomically after provider confirmation, with idempotent retry and reconciliation; Square and the database cannot share one transaction.
- ☐ ~ Automatically flag confirmed paid checkouts with no entry, archived entries, missing event codes, and unrevealed entries during a challenge hold; venue/simulator attempt signals are still needed for broader usability decisions.
- ☐ ~ Notify staff of reconciliation failures, customer/staff of actionable paid-entry issues, and customers of persistent email/entry-payment mismatches; unverified technical-only failures are intentionally staff-only.
- ☒ OK Preserve append-only claim/refund events with separate email-delivery markers.

6. Payment Reliability and Reconciliation

- ☒ OK Verify Square webhook signatures in production.
- ☒ OK Verify Square order ID, amount, currency, and completed-payment state before granting access.
- ☒ OK Use idempotent entry creation for Square completion and webhook races.
- ☒ OK Record checkout, payment, entry, access, and confirmation-email audit events.
- ☒ OK Add a Vercel daily reconciliation job that verifies Square payments, repairs paid-without-entry checkouts, and identifies entry-without-payment mismatches.
- ☐ ~ Unsent confirmation emails are retried from persisted checkout state with per-audience delivery markers; webhook delivery still relies on Square retries plus the scheduled provider sweep, not an application-managed webhook inbox.
- ☒ OK Add persistent administrator reconciliation issues, email alerts, and an authenticated queue/dashboard with manual batch rerun.
- ☐ ~ MFA administrators can place attributed, customer-notified account participation holds that block new Square purchases, simulator-code access, and result verification after an eligibility or legal-acceptance concern is found; automatic invalidity detection and full legacy-path audit remain open.

7. Privacy Operations

- ☐ ~ The Privacy Policy publishes an email contact channel; signed-in and signed-out online intake and signed-in appeal review now exist, but signed-out appeals and email intake still need manual queue entry.
- ☒ OK Support access, correction, deletion, portable-copy, opt-out, and appeal request intake types.
- ☐ ~ Record a 45-day target, one documented extension, identity-review status, decisions, customer responses, and appeal history; the real-world identity-verification procedure is not yet defined.
- ☐ ~ Add an MFA administrator appeal-review queue; safe export, correction, deletion, and anonymization tools are still needed.
- ☐ Adopt and encode a data-retention schedule by record type.
- ☐ ~ Create a candidate service-provider inventory from integrations; owner must verify actual production vendors, contracts, data categories, and subprocessors.
- ☐ ~ Refund evidence is privately stored and owner/MFA-admin retrievable with audit events; winner identity/tax documents are deliberately not collected by this app pending secure collection design.
- ☐ ~ Document deletion exceptions in the privacy operations runbook; owner/counsel still need to approve and encode record-specific retention decisions.

8. Security and Administration

- ☒ OK Use one-hour rolling player sessions with server-side expiration.
- ☒ OK Use secure, HTTP-only production session cookies.
- ☒ OK Hash player passwords with scrypt and a unique per-password salt.
- ☐ ~ Database-backed rate limiting now protects authentication, recovery, checkout, verification resend, contact, and payment-issue claim endpoints; other future sensitive endpoints must adopt the same control.
- ☒ OK Require a short-lived, single-use email verification code after the individual administrator password.
- ☐ ~ Shared production credentials were replaced with allowlisted individual user accounts; role-based authorization is not yet implemented.
- ☒ OK Add same-origin enforcement to sensitive cookie-authenticated mutations while exempting signed webhooks and bearer-authenticated simulator integrations.
- ☒ OK Add production security headers, clickjacking protection, HSTS, and a Content Security Policy.
- ☐ Validate future evidence uploads by type and size and add malware controls.
- ☐ Encrypt or isolate sensitive winner documents with least-privilege access.
- ☐ ~ A backup, restore, secret-rotation, access-review, and incident-response runbook exists; provider configuration and a recorded restore drill remain outstanding.
- ☒ OK Replace destructive entry deletion with attributed, timestamped archival that is excluded from active views.

9. Communications, Testing, and Launch

Manual execution guide: [Consent and payment mobile test script](CONSENT_AND_PAYMENT_MOBILE_TEST_SCRIPT.md).

- ☐ ~ Include the stored accepted-document version and legal package hash in Square confirmation email; exact challenge details still need a verified configuration snapshot.
- ☐ ~ Link current rules and refund support from Square payment confirmation emails; other entry communications need review.
- ☐ ~ Unit tests cover legal-document hashes, required account consent, session expiration, Square verification, and idempotency; full browser coverage is not implemented.
- ☐ Test account creation, login, already-signed-in QR scans, and Square redirects on supported mobile browsers.
- ☐ Test challenge state and time boundaries in the browser and directly against the API.
- ☐ ~ Unit tests cover chronology ordering, identical and unreliable timestamps, and simulator-secret-only ingestion; concurrent verification and closure need production-like database testing.
- ☐ Test automatic refunds for unused entries after challenge closure.
- ☐ ~ Unit tests cover the refund timing flag, entry review signals, upload validation, and Square refund requests; production-like deadline and audit-history testing remains.
- ☐ ~ Unit tests cover Square payment validation, duplicate entry creation, and partial confirmation-email retry; production-like webhook delay, duplicate, and reconciliation testing remains.
- ☐ Complete accessibility and mobile checkout review.
- ☒ OK Insert the owner-confirmed effective date and business mailing address in the legal package.
- ☐ ~ Owner reported counsel acceptance of the current terms package; retain written approval and obtain remaining CPA sign-off.
- ☐ ~ Remove website draft banners after reported approval; internal launch material remains in the source package but is excluded from published routes.
- ☐ Complete a production launch rehearsal before enabling paid entries.

Owner and Professional Inputs Still Required

- Preserve the Texas attorney's written approval record and confirm whether the online-claim sentence needs an additional review.
- CPA-approved tax collection, withholding, reporting, and payout procedure.
- Confirmation that the advertised prize is reserved or insured.
- Final challenge course, hole, tee, pin, target distance, simulator configuration, sale period, and participating locations.
- Decision on how existing-account acceptance and transaction-specific onsite presence will be documented without interrupting repeat QR checkout.